

Custorian: A Compliance Standard for Child Digital Safety

An Open Framework for Platform Certification, Institutional Intelligence, and Regulatory Conformity

Authors: T. Becheva **Affiliation:** Foreningen Custorian, Odense, Denmark
Contact: tanya@custorian.org **Date:** April 2026 **Standard alignment:** IEEE P3462
(Safety by Design for GenAI to Prioritize Child Safety) **Classification:** White Paper
— Pre-Publication Draft

Abstract

On April 3, 2026, the temporary derogation to the EU ePrivacy Directive expired, removing the legal basis for platforms to voluntarily detect child sexual abuse material (CSAM) in the EU. No replacement legislation is in force. Simultaneously, the Digital Services Act, EU AI Act, and national laws such as Denmark’s under-15 social media ban mandate child protection outcomes but provide no shared technical standard for achieving them. This paper introduces the Custorian Standard: an open compliance framework comprising the Custorian Controls Framework (CCF), the Custorian API Specification (CAS), and a tiered certification programme. Modelled on PCI DSS for payment security and EPEAT for sustainable electronics, the standard defines 116 auditable controls across six domains that platforms certify against. Built on IEEE P3462 and extending its recommended practices into enforceable controls, the CCF requires on-device detection architectures that address the tension between child protection and privacy preservation — a tension that has stalled the EU’s CSA Regulation and contributed to the abandonment of Apple’s NeuralHash initiative. We present the framework architecture, threat model, compliance model, institutional intelligence requirements, and regulatory cross-mapping.

Keywords: child safety, compliance framework, platform certification, IEEE P3462, Safety by Design, DSA, EU AI Act, ePrivacy, open standard

Table of Contents

1. Introduction — ePrivacy gap, the broader crisis, industry analogues, IEEE P3462

2. Framework Architecture — CCF overview, 6 control domains, control numbering
3. Threat Model — Adversary types, attack surface, trust boundaries
4. On-Device Detection Requirement — On-device mandate, age verification failure modes, multi-device consistency, intervention content safety
5. Children’s Rights Framework — UNCRC alignment, parental abuse safeguards, age-out lifecycle, accessibility, detection category ethics
6. Data Privacy and Institutional Intelligence Requirements — Privacy architecture, de-identification, consent, incident response SLAs, evidence preservation
7. Regulatory and Standards Landscape — Key regulations, pending legislation, normative standards
8. Compliance Model — Platform levels, validation, certification, versioning, responsible disclosure, liability positioning
9. API Specification (CAS) — OpenAPI endpoints
10. Adoption Lifecycle — Staged adoption, stakeholder incentives, comparison with existing approaches
11. Regulatory Cross-Mapping — CCF-to-regulation mapping
12. Implementation Roadmap
13. Liability and Scope of Protection
14. Conclusion

Appendix A: Planned Validation Pilot Design

1. Introduction

1.1 The Immediate Crisis: The ePrivacy Gap

On April 3, 2026, the temporary derogation to the EU ePrivacy Directive expired [32]. This derogation was the legal basis that allowed technology platforms to voluntarily detect and report child sexual abuse material (CSAM). **As of this writing, platforms operating in the EU have no legal basis to scan for CSAM.** The proposed CSA Regulation remains in trilogue negotiations (4th meeting expected May 2026) [33].

This creates an unprecedented gap: 36.2 million CSAM reports were submitted to NCMEC in 2023 [1]. With the legal basis for detection expired and no replacement in force, that detection capacity is suspended in the EU.

The CCF requires on-device processing for independent privacy reasons (see Section 4.1). However, this architectural choice has a regulatory consequence worth noting: because all analysis occurs locally on the child’s device — and only cryptographic hash matches (not message content) are reported — the processing is architecturally distinct from the server-side scanning contemplated by the expired derogation. On-device processing initiated by the device owner (parent/guardian) with informed consent, where no data is transmitted to external servers, may fall outside the scope of Articles 5(1) and 15(1) of the ePrivacy Directive (2002/58/EC).

This is an architectural observation, not a legal claim. Whether on-device detection constitutes “interception” under ePrivacy has not been tested in court or formally assessed by a data protection authority. Custorian does not assert that the CCF resolves the ePrivacy gap — that determination belongs to legislators, courts,

and data protection authorities. Custorian is seeking a formal legal opinion from a qualified EU data protection practitioner and intends to engage with the EDPB and/or Danish Datatilsynet for informal guidance.

1.2 The Broader Problem

Beyond the immediate ePrivacy crisis, the scale of child digital harm is well-documented. The NCMEC received 36.2 million CSAM reports in 2023 [1]. Research cited in the WeProtect Global Alliance's 2023 Global Threat Assessment found that predators can escalate from first contact to exploitation request within an average of 45 minutes in social gaming environments [2]. UNICEF polling across 30 countries found that more than 1 in 3 young people report being a victim of online bullying [3]. CDC data shows significant increases in emergency department visits for self-harm among adolescents, with visits among girls aged 10-14 increasing approximately fivefold since 2009 [4]. The FBI issued an alert in 2023 on the surge in financial sextortion targeting minors [36].

Despite these statistics, the digital industry lacks a shared compliance framework for child safety. Existing approaches are fragmented:

- **Consumer tools** (Bark, Qustodio, Net Nanny) are proprietary and cloud-dependent, transmitting children's message content to third-party servers for analysis. While multi-language interfaces exist, content analysis capabilities remain heavily English-centric, with limited NLP detection in other languages [5].
- **Platform-specific measures** vary widely in scope and effectiveness. External audit mechanisms are emerging — Ofcom under the UK Online Safety Act, EU Digital Services Coordinators under the DSA — but enforcement is nascent and has not yet produced systematic cross-platform comparability [6].
- **Regulatory frameworks** (DSA, AI Act, AADC) mandate child protection outcomes but delegate technical implementation to standards bodies. Relevant standards exist (IEEE 2089-2021 for age-appropriate digital services) and harmonised standards are in development under the AI Act via CEN/CENELEC, but no comprehensive compliance framework analogous to PCI DSS exists for child digital safety [7].

This gap — between regulatory intent and technical implementation — is what the Custorian Standard addresses.

1.3 Analogues in Other Industries

PCI DSS (Payment Card Industry Data Security Standard) was created in 2004 to address inconsistent payment security. It defines specific controls, validation procedures, and compliance levels. Organisations that process payment cards must certify annually. The standard is maintained by the PCI Security Standards Council, funded by the industry it regulates [8].

EPEAT (Electronic Product Environmental Assessment Tool) was seeded by US EPA funding and subsequently mandated by the US federal government for IT procurement. Manufacturers pay annual registry fees. The standard is maintained by the Global Electronics Council (GEC) as a non-profit [9].

Custorian proposes the same model for child digital safety: an open standard, maintained by a non-profit, with government endorsement driving industry adoption through mandatory certification.

1.4 Relationship to IEEE P3462

Custorian is built on IEEE P3462, the forthcoming Recommended Practice for Using Safety by Design in Generative Models to Prioritize Child Safety [10]. Custorian extends P3462 in three ways:

1. **Scope expansion:** P3462 focuses on generative AI. Custorian covers all digital platforms that interact with children.
 2. **Enforceability:** P3462 provides recommended practices. Custorian provides auditable controls with testing procedures and certification outcomes.
 3. **Detection implementation:** P3462 recommends detection of CSAM and harmful content. Custorian provides an open API specification (CAS) defining how platforms implement detection, reporting, and interoperability.
-

2. Framework Architecture

2.1 Overview

The Custorian Standard comprises three components:

1. **Custorian Controls Framework (CCF)** — What platforms must do (analogous to PCI DSS requirements)
2. **Custorian API Specification (CAS)** — How platforms implement detection, reporting, and interoperability (analogous to PA-DSS / PCI 3DS SDK)
3. **Custorian Certification Programme** — How compliance is validated and certified (analogous to PCI QSA programme)

2.2 Control Domains

The CCF is organised into six control domains:

Domain	Code	Controls	Scope
Age Controls	CS-AC	18	Age determination, age-appropriate defaults, feature gating, verification failure modes
Content & Design Safety	CS-CD	29	Harmful content detection, dark pattern prohibition, moderation standards,

Domain	Code	Controls	Scope
			intervention content safety, accessibility
Data & Privacy for Minors	CS-DM	13	Data minimisation, on-device processing, DPIA, advertising prohibition
Parental Rights & Controls	CS-PR	14	Parent dashboards, safety boundaries, child notification, teen autonomy
Monitoring, Detection & Response	CS-MR	28	Real-time detection, accuracy transparency, incident response SLAs, mandatory reporting, evidence preservation, multi-device consistency
Governance & Policy	CS-GO	14	Child Safety Officers, training, vendor management, regulatory mapping, responsible disclosure, jurisdictional compliance

Total: 116 defined controls in the current draft (CCF v0.1) across 6 domains, with each control classified as Required or Addressable. Control count and classification are subject to revision through advisory council review and pilot validation.

2.3 Control Numbering

Controls follow the format CS– [DOMAIN] . [REQUIREMENT] . [CONTROL] :

CS–MR.1.3

CS = Custorian Standard

- MR = Monitoring, Detection & Response
- 1 = Requirement: Real-time threat detection
- 3 = Control: Detection accuracy reporting

Testing procedures are appended as suffixes: CS-MR.1.3.a, CS-MR.1.3.b.

3. Threat Model

3.1 Adversary Types

Adversary	Sophistication	Goal	Typical Vector
Opportunistic predator	Low	Access to child, image solicitation	Public social media DMs, gaming chat, dating apps with no age verification
Organised exploitation network	High	CSAM production and distribution, trafficking	Coordinated grooming across platforms, rapid migration to encrypted channels
Financial sextortion operator	Medium-High	Financial extortion via intimate image threats	Social media DMs, fake profiles, rapid escalation to payment demands
Peer aggressor (bully)	Low-Medium	Social harm, exclusion, humiliation	School-linked messaging apps, group chats, social media comments
AI-assisted groomer	Medium-High (increasing)	Scaled grooming using LLM-generated messages	Multiple simultaneous targets, personalised manipulation, rapid adaptation
Radicalisation recruiter	Medium-High	Ideological radicalisation, real-world violence	Gaming platforms, fringe social media, private messaging groups

3.2 Attack Surface

The CCF defines a detection perimeter based on text-based communication accessible to on-device processing:

Inside the detection perimeter: Text input and display across messaging apps, in-app messaging on social media, gaming, and communication platforms, SMS and standard messaging protocols.

Outside the detection perimeter (acknowledged blind spots): End-to-end encrypted platforms that block on-device access, voice and video communication, image-only communication without text, dark web services, and communication on devices not running a CCF-compliant application. These blind spots define the boundary of what any on-device standard can achieve. They also define why platform cooperation matters: platforms that enable CCF-compliant detection within their environments provide measurably better child protection than those that do not.

3.3 Trust Boundaries

Boundary	Who is trusted	Risk if violated
Parent-child	Parent acts in child’s best interest	Abusive parent uses monitoring data to control or punish child (see Section 5.2)
Device integrity	Device OS enforces app sandboxing and API access	Rooted/jailbroken device could bypass detection
Pattern library	Detection pattern updates are authentic and untampered	Compromised update server could disable detection or inject false patterns
Institutional data	Schools and municipalities use aggregate data for child welfare	Misuse of aggregate data for profiling, discrimination, or punitive action

4. On-Device Detection Requirement

4.1 Why the CCF Mandates On-Device Processing

A fundamental tension exists in child safety technology: effective detection requires analysis of private communications, but cloud-based analysis violates the privacy principles that protect children under GDPR and the UNCRC [11].

The CCF resolves this by requiring that all threat detection runs locally on the child’s device (CS-MR.1.1). Message content never leaves the phone. This architecture eliminates cloud-based data breaches, third-party data access, bulk surveillance infrastructure, and cross-border data transfer complications.

This is both a technical requirement and a regulatory strategy. Apple’s 2021 NeuralHash initiative — an on-device CSAM detection system — was abandoned after backlash stemming from proprietary governance, lack of transparency, and no user consent mechanisms [39][40]. The CCF addresses each of these failures through open-source transparency, non-profit governance, mandatory parental consent, and QSA-audited compliance. The lesson from NeuralHash is not that on-device detection is impossible — it is that on-device detection without institutional trust architecture is untenable.

4.2 What the CCF Requires of Detection Implementations

The CCF defines *what* a compliant detection system must achieve, not *how*. Key requirements include:

- **CS-MR.1.1:** Real-time threat detection across 7 defined categories (grooming, bullying, self-harm, violence, content wellness, sextortion, dangerous purchases)
- **CS-MR.1.3:** Published detection accuracy metrics (precision, recall, false positive/negative rates) per language, updated quarterly
- **CS-MR.2.1:** Mandatory reporting to law enforcement for CSAM detection within 1 hour
- **CS-DM.1.1:** On-device processing by default; no message content transmitted to external servers
- **CS-PR.3.1:** Mandatory notification to children aged 13+ that monitoring is active

4.2.1 Age Verification Failure Modes (CS-AC.2)

Age verification is the primary bypass mechanism for child safety controls. The CCF defines requirements for what happens when verification fails or is inconclusive:

- **CS-AC.2.1 (Default to maximum protection):** When age cannot be verified or verification is inconclusive, the system must default to the youngest applicable age bracket (8-10) and apply maximum protection settings. Under-protection due to failed verification is a more serious failure mode than over-protection.
- **CS-AC.2.2 (Multi-signal degradation):** If the primary age verification signal fails (e.g., eIDAS wallet unavailable), the system must fall back to secondary signals (parent attestation, device family account) rather than disabling age-gated features.
- **CS-AC.2.3 (Verification logging):** All age verification events — successful, failed, and inconclusive — must be logged for QSA audit purposes. No personal data is retained; only the verification method, outcome, and timestamp.

4.2.2 Multi-Device Consistency (CS-MR.3)

Children increasingly use multiple devices (personal phone, family tablet, school-issued device). The CCF requires:

- **CS-MR.3.1:** When a child profile is active on multiple devices, detection must be consistent across all devices. A threat detected on one device must be reflected in the parent dashboard regardless of which device generated the alert.
- **CS-MR.3.2:** Institutional opt-in consent applies per child, not per device. A parent who opts in to school mode does not need to re-consent for each device.
- **CS-MR.3.3:** Detection history is synchronised across devices via encrypted on-device sync (e.g., iCloud Keychain, Google Backup) — not via Custorian servers.

The CAS API specification provides the technical interface for platforms building CCF-compliant detection systems.

4.3 Intervention Content Safety (CS-CD.3)

When a CCF-compliant system delivers interventions to a child — nudges, warnings, guidance, or safety information — the content itself becomes a safety surface. A child who receives an intervention may treat it as a trusted adviser, confide in it, or act on its guidance. The CCF therefore defines requirements for what intervention content may and may not contain:

Required (CS-CD.3.1 — AI classification / human intervention split): - AI may be used to *classify* content (threat category, severity, patterns). AI must not *generate* the text that children read. Child-facing intervention content must be pre-authored by qualified child safety professionals and selected by the classification engine based on category, severity, and age bracket. - This split allows AI-powered safety features (e.g., a child shares a suspicious message and receives a structured safety assessment) while ensuring that the words the child reads were written and reviewed by humans — not generated in real time by an LLM. - Interventions must not provide counselling, therapy, diagnosis, or medical advice. They must direct children to qualified human support (school counsellor, national helpline, trusted adult). - Interventions must not describe threat mechanics in detail. A grooming intervention must not explain grooming tactics in a way that desensitises the child or educates a peer aggressor. - Interventions for self-harm or suicidal ideation must follow established media guidelines for safe messaging (e.g., Recommendations for Reporting on Suicide, reportingonsuicide.org) and must always surface a crisis helpline with one-tap access.

Required (CS-CD.3.2 — Age-appropriate language): - Intervention tone, vocabulary, and consequence framing must be calibrated to the child's verified age bracket. - Interventions for children under 13 must not include fear-based messaging, graphic descriptions, or criminal justice framing.

Required (CS-CD.3.3 — Cultural and contextual review): - Intervention content must be reviewed for cultural appropriateness in each supported language and region. Generic translations of English-language interventions are not compliant. - Intervention content must not make assumptions about family structure, religious context, or gender identity.

Required (CS-CD.3.4 — No dialogue loop): - The child must not be able to enter into a back-and-forth dialogue with the intervention system. One-shot interactions are permitted: a child may submit content (e.g., via a Share Extension) and receive a single structured safety assessment. The system does not respond to follow-up messages, ask clarifying questions, or sustain a conversation. - This requirement prevents the child from treating the system as a counsellor, confidant, or therapist — roles that require qualified human professionals. A child may use the safety assessment feature repeatedly (each time submitting new content), but each interaction is independent — there is no conversation history, no memory of prior submissions, and no relationship-building. - AI-generated free-text responses to children are prohibited. All child-facing text must be selected from pre-authored templates, even when AI is used for the underlying classification.

Required (CS-CD.3.5 — Intervention content governance): - All intervention content must be version-controlled and published in the open-source repository. - Changes to intervention content require review by at least one qualified child

psychologist or child safety professional, documented in the public changelog. - The Advisory Council's Category Ethics Review function (Section 5.4) extends to intervention content review.

Rationale: The intervention is the moment of highest trust between the system and the child. If the system delivers harmful, inappropriate, or culturally insensitive guidance at the moment a child is most vulnerable, the damage compounds the original threat rather than mitigating it. These controls ensure that the intervention layer is as rigorously governed as the detection layer.

5. Children's Rights Framework

5.1 UNCRC Alignment

The CCF engages with the tension between protection rights and participation/privacy rights under the UNCRC:

Right	Article	Tension	CCF Resolution
Protection from harm	Art. 19	Justifies monitoring	On-device detection identifies threats
Privacy	Art. 16	Monitoring intrudes on privacy	On-device processing: no data leaves device. Message content never viewed by parents, school, or Custodian. Only anonymised metadata shared with consent.
Right to be heard	Art. 12	Children should have voice	Child notification mandatory for 13+ (CS-PR.3.1). Age-appropriate interventions empower child to act.
Best interests	Art. 3	All actions should prioritise child	Architecture designed for empowerment, not surveillance. Neither parent nor institution receives raw message content.
Evolving capacities	Art. 5	Protection should decrease as child matures	Age-graduated thresholds: maximum protection at 8-10, minimal intervention at 17+.

This framework draws on UNCRC General Comment No. 25 (2021) [11] and UNICEF's Policy Guidance on AI for Children [13].

5.2 Parental Abuse and Misuse Safeguards

The CCF addresses the scenario where the parent is the threat through mandatory architectural safeguards:

1. **CS-PR.2.1:** Parents never see message content. Alerts contain category, severity, and timestamp only.

2. **CS-PR.3.1:** Mandatory child notification (ages 13+). Non-configurable.
3. **CS-PR.4.1:** Age-graduated autonomy. Detection sensitivity decreases and child agency increases with age.
4. **CS-PR.2.3:** No keyword reporting. Only pattern-level threat categories.
5. **CS-PR.5.1 (planned):** Child self-reporting mechanism routing to school counsellor or national helpline, bypassing the parent.

These safeguards reduce but do not eliminate misuse risk. The planned Advisory Council will include survivor and lived-experience voices to inform ongoing design.

5.3 Age-Out Lifecycle

When a monitored child reaches 18, the CCF requires: automatic cessation of monitoring, parent access revocation, on-device data deletion within 24 hours, and young adult data access rights (GDPR Art. 15) before automatic erasure (Art. 17). Institutional aggregate data is unaffected (anonymised, non-traceable). The age-out is automatic, not parent-initiated.

5.4 Accessibility Requirements (CS-CD.4)

Children with disabilities must receive equivalent protection. The CCF requires:

- **CS-CD.4.1:** All child-facing interventions must be compatible with platform screen readers (VoiceOver on iOS, TalkBack on Android). Interventions must not rely solely on visual presentation.
- **CS-CD.4.2:** Intervention text must meet WCAG 2.1 AA contrast and readability requirements.
- **CS-CD.4.3:** Crisis helpline actions (one-tap call) must be accessible to children using assistive input devices.
- **CS-CD.4.4:** The planned validation study (Appendix A) must include assessment of accessibility compliance and should recruit families of children with disabilities where possible.

5.5 Detection Category Ethics

The CCF's 7 detection categories were defined based on published threat taxonomies (NCMEC, EU Kids Online, Thorn) and IEEE P3462's recommended scope. Two categories warrant ethical scrutiny: "content wellness" (including radicalisation indicators) where the boundary with legitimate political expression is contested, and "dangerous purchases" (including vape/drug references) which is a parental monitoring function rather than a child safety function in the UNCRC sense. The Advisory Council will include a Category Ethics Review function with digital rights representation to challenge scope creep.

6. Data Privacy and Institutional Intelligence Requirements

The CCF defines requirements for how child safety data is handled across institutional tiers.

6.1 Privacy Architecture Requirements

The CCF mandates a three-tier privacy architecture:

1. **Family tier (CS-DM.1.1):** All detection processing occurs on-device. No message content is transmitted to any external server. Parents receive alerts containing category, severity, and timestamp only — never message content.
2. **Institutional tier (CS-DM.2.1):** When parents explicitly opt in, only anonymised metadata (category, severity, timestamp, age bracket) is shared with institutional dashboards. No names, messages, or device identifiers are transmitted.
3. **Aggregation tier (CS-DM.3.1):** Data aggregates upward through institutional layers (school, municipality, region, national), becoming more aggregated and less granular at each level. No tier can access individual-level data from the tier below.

6.2 De-identification Requirements

The CCF requires de-identification following the HIPAA Safe Harbor method adapted for child safety data:

- No direct identifiers (names, device IDs, IP addresses, contact information)
- Quasi-identifier suppression (age limited to 4-year brackets, timestamps limited to 4 periods)
- Small-cell suppression (cells with fewer than 5 observations are hidden)
- k-anonymity ($k \geq 5$) — each data point indistinguishable from at least 4 others
- Differential privacy (planned for CCF v2.0) for national-level aggregates

6.3 Consent and Withdrawal Requirements

- **CS-PR.1.1:** Informed consent required before any institutional data sharing, with plain-language explanation of what is shared, with whom, and how to withdraw
- **CS-PR.1.2:** Consent is granular (per institution) and revocable (one-tap withdrawal)
- **CS-PR.1.3:** Upon withdrawal, metadata transmission stops immediately. Historical anonymised data is not retroactively deleted (genuinely anonymised, non-traceable). GDPR Art. 17 is satisfied by the act of withdrawal, as no personal data is held at institutional tiers.
- **CS-DM.4.1:** Anonymised aggregate data retained for 5 years (school level) / 10 years (municipal/national level)

6.4 Cross-Border Reporting Requirements

- **CS-MR.2.1:** Mandatory reporting to law enforcement for CSAM detection within 1 hour
- **CS-MR.2.2:** The CAS /report endpoint routes reports to the appropriate national authority based on the child's jurisdiction, with NCMEC CyberTipline as the international clearing house via the INHOPE network

6.5 Jurisdictional Conflict Resolution (CS-GO.6)

Platforms operating across multiple jurisdictions face materially conflicting requirements for child digital safety — including divergent definitions of “child” (under 13 in US COPPA, under 15 in Denmark, under 16 in GDPR default and Australia, under 18 in UK AADC), incompatible data retention obligations, and jurisdiction-specific mandatory reporting channels. The following controls establish how CCF-compliant platforms resolve these conflicts without defaulting to the lowest common denominator or the law of the platform’s home jurisdiction.

- **CS-GO.6.1:** The applicable jurisdiction for any child account must be determined by the child’s location of residence or habitual use, not the platform’s country of incorporation or server location. Platforms must implement reliable jurisdiction detection at account creation and re-evaluate periodically (at minimum annually or upon detected location change).
- **CS-GO.6.2:** Where two or more jurisdictional requirements conflict on a substantive child safety matter — including age thresholds, consent requirements, data minimisation, or content restrictions — the platform must apply the more protective standard. “More protective” is defined as the higher age threshold, the stricter data handling requirement, or the narrower permitted use of minor data.
- **CS-GO.6.3:** Platforms must maintain a jurisdiction-specific configuration layer that adjusts age thresholds, parental consent mechanisms, data retention periods, and mandatory reporting obligations based on each child’s determined jurisdiction. This configuration must be auditable and updated within 90 days of any relevant legislative change in a covered jurisdiction.
- **CS-GO.6.4:** Mandatory reporting of CSAM, grooming, or imminent danger must be routed to the competent national authority of the child’s jurisdiction — not the platform’s headquarters jurisdiction. Where an international clearing house exists (e.g., NCMEC CyberTipline via INHOPE), the platform must use both the direct national channel and the clearing house to ensure no report is lost in jurisdictional handoff.
- **CS-GO.6.5:** Platforms must publish a Jurisdictional Compliance Map documenting, for each jurisdiction in which minors use the platform, which national or supranational standard governs each CCF control. This map must be updated at least annually, reviewed by the designated Child Safety Officer (CS-GO.1.1), and made available to auditors and regulators upon request.

6.6 Tiered Incident Response SLAs (CS-MR.4)

Different threat categories require different response timelines:

Tier	Threat categories	Response SLA	Action required
Critical	CSAM hash match, imminent physical danger	1 hour	Automated law enforcement report via CAS /report. Parent alert: immediate push notification.
Urgent	Self-harm (severity >80/100), sextortion,	4 hours	Parent alert: elevated push notification. If institutional mode active: school

Tier	Threat categories	Response SLA	Action required
Standard	grooming (severity >80/100)	24 hours	counsellor flagged within 4 hours on next business day.
	Bullying, violence, grooming (severity <80), content wellness		Parent alert: standard notification. Institutional dashboard updated in next sync cycle.
Informational	Dangerous purchases, content wellness (low severity)	48 hours	Parent alert: digest notification. No institutional escalation.

Institutions deploying CCF-compliant systems must define their own internal response procedures downstream of these SLAs — the CCF defines when the alert must be delivered, not what the institution does with it.

6.7 Evidence Preservation (CS-MR.5)

When a CSAM hash match triggers a mandatory law enforcement report:

- **CS-MR.5.1:** The detection event (timestamp, hash match identifier, device locale, CAS report ID) must be preserved in a tamper-evident log on-device for a minimum of 12 months or until law enforcement confirms the investigation is closed.
- **CS-MR.5.2:** The tamper-evident log must use cryptographic chaining (hash chain) so that any modification is detectable.
- **CS-MR.5.3:** No message content is preserved — only the detection metadata and hash match identifier. This is sufficient for law enforcement to correlate with the NCMEC CyberTipline report.
- **CS-MR.5.4:** The evidence log is accessible only to the device owner (parent) and, upon lawful request, to law enforcement. It is not accessible to Custodian, schools, or any institutional tier.

6.8 Ethical Framework

The institutional data architecture draws on Nissenbaum (2010) [15] on contextual integrity, Solove (2006) [16] on data minimisation, and Beauchamp & Childress (2019) [17] on informed consent. The CCF transmits only four data points per alert — the minimum viable data for institutional intelligence.

7. Regulatory and Standards Landscape

The Custodian Standard operates within a rapidly evolving regulatory environment. A complete cross-mapping is provided in the Regulatory Cross-Mapping Companion Document.

7.1 Key Regulations

Regulation	Status	CCF Alignment
EU Digital Services Act — Art. 28 (minor protection), Art. 34 (systemic risk assessment for VLOPs), Art. 35 (risk mitigation), Art. 37 (independent audit)	In force (2024)	CS-AC, CS-CD, CS-PR, CS-GO map directly. CAS provides technical implementation.
EU AI Act — Children protected as vulnerable group throughout; Art. 5 prohibits exploitation of children’s vulnerabilities; Annex III classifies education AI as high-risk; high-risk classification criteria include age and vulnerability (Regulation 2024/1689)	In force (2025-2026, phased)	CS-MR covers accuracy, transparency, oversight. On-device satisfies Art. 10 data governance.
UK Age Appropriate Design Code — 15 standards	In force (2021)	All 15 AADC standards mapped to CCF controls.
Denmark Under-15 Social Media Law	Political agreement Nov 2025; legislation expected 2026	CS-AC.1 supports compliance directly.
EU ePrivacy Derogation	Expired April 3, 2026	On-device architecture provides detection without ePrivacy “interception” (see Section 1.1).

7.2 Key Pending Legislation

Regulation	Status	CCF Relevance
EU CSA Regulation	Trilogue (May 2026)	On-device resolves “chat control” impasse. Hash-matching supports proposed obligations.
EU Digital Identity Wallet (eIDAS 2.0) — Wallet availability mandated Nov 2026; business acceptance Nov 2027	In force (phased)	CS-AC.1.4 designed for day-one wallet integration.
Jutland Declaration	Signed Oct 2025, Horsens	Validates EU-wide political will. Signed in Horsens, Denmark.

7.3 Normative Standards

IEEE P3462 [10] is the primary normative basis; the author is a contributing Working Group member. Additional standards: IEEE 2089-2021, IEEE 7000-2021, IEEE 7002-2022, IEEE 7003-2024, ISO/IEC 27701, NIST AI RMF. CEN/CENELEC submission planned.

8. Compliance Model

8.1 Platform Levels

Level	Minor Users	Validation	Frequency
1	>1M	Qualified Safety Assessor (QSA) audit	Annual + quarterly accuracy reports
2	100K-1M	QSA audit or Self-Assessment Questionnaire	Annual
3	10K-100K	Self-Assessment Questionnaire	Annual
4	<10K	Simplified Self-Assessment	Annual

8.2 Validation Instruments

- **Self-Assessment Questionnaire (SAQ):** Platform self-reports compliance per control
- **Report on Compliance (ROC):** QSA-validated comprehensive assessment
- **Quarterly Accuracy Report:** Detection precision, recall, and false positive rates per language

8.3 Certification Outcomes

- **Custorian Certified:** Listed on public registry. Certification mark licence.
- **Custorian Non-Compliant:** Identified gaps documented. Remediation plan required.

8.4 Standard Versioning and Transition

When the CCF is updated (e.g., v1.0 to v1.1):

- **Sunset period:** Platforms certified under the previous version have 12 months from the new version’s publication date to re-certify. During this period, existing certifications remain valid.
- **Backward compatibility:** New versions must document all changes from the previous version, classified as: new controls (additions), modified controls

(changes to existing requirements), and deprecated controls (removals).

Platforms can assess the delta rather than re-certifying from scratch.

- **Breaking changes:** Controls that fundamentally change compliance requirements (e.g., new mandatory controls) trigger a mandatory re-assessment. Addressable controls that become Required receive 18 months rather than 12.
- **Version registry:** The public certification registry displays both the CCF version a platform was certified against and whether that version is current, in sunset, or expired.

8.5 Responsible Disclosure for Compliance Failures

If a researcher, journalist, civil society organisation, or member of the public discovers that a certified platform is not actually compliant:

- **CS-GO.5.1:** Custorian maintains a public responsible disclosure policy and secure reporting channel (security@custorian.org).
- **CS-GO.5.2:** Reports are triaged within 5 business days. Confirmed compliance failures trigger a 30-day remediation window for the platform before public disclosure.
- **CS-GO.5.3:** If a platform fails to remediate within 30 days, Custorian publishes the compliance failure on the public registry and may suspend or revoke certification.
- **CS-GO.5.4:** Reporters are protected. Custorian will not pursue legal action against good-faith compliance failure reports, consistent with EU Whistleblower Directive (2019/1937) principles.

8.6 Liability Positioning

The CCF is designed to create regulatory incentive alignment, not legal immunity:

- **Presumption of conformity:** Platforms that are Custorian Certified may cite certification as evidence of reasonable measures under DSA Art. 28, AI Act conformity assessments, and AADC compliance — analogous to how PCI DSS compliance demonstrates reasonable security measures in payment card breach litigation.
- **Non-compliance liability exposure:** The CCF does not create new legal obligations. However, as the standard gains government endorsement and regulatory reference, non-certified platforms may face increased scrutiny from regulators who use CCF as a benchmark for “appropriate measures” — mirroring how non-PCI-compliant merchants face shifted liability in payment disputes.
- **No indemnification:** Custorian Certified status does not indemnify platforms against liability for child safety incidents. Certification demonstrates process conformity, not outcome guarantee.

9. API Specification (CAS)

The Custorian API Specification defines the technical interface that platforms implement for CCF compliance. It is published as an OpenAPI 3.1 document and covers two categories:

Platform compliance endpoints (what platforms must expose for certification):

Endpoint	Method	Purpose	CCF Control
/custorian/v1/detect	POST	Real-time threat analysis	CS-MR.1.1
/custorian/v1/age/verify	POST	Multi-signal age verification	CS-AC.1, CS-AC.2
/custorian/v1/accuracy	GET	Published detection accuracy metrics (quarterly)	CS-MR.1.3
/custorian/v1/report	POST	Mandatory CSAM/danger reporting to law enforcement	CS-MR.2.1
/custorian/v1/audit	GET	QSA compliance audit trail	CS-GO.1

Institutional intelligence endpoints (what CCF-compliant systems expose to schools/municipalities):

Endpoint	Method	Purpose	CCF Control
/custorian/v1/intelligence/aggregate	GET	Anonymised threat data for institutional dashboards	CS-DM.2.1
/custorian/v1/intelligence/benchmark	GET	Cross-institutional comparison metrics	CS-DM.3.1

The CAS does not define consumer application endpoints (parent dashboards, alert UIs, parental controls). These are implementation decisions for developers building CCF-compliant applications, not requirements of the standard.

Full OpenAPI 3.1 specification will be published alongside the first QSA programme.

10. Adoption Lifecycle

10.1 Staged Adoption

The standard is designed for bottom-up adoption: families adopt CCF-compliant applications, schools subscribe to aggregate dashboards, municipalities deploy, government endorses, platforms certify. Each stage creates data that makes the next tier viable, mirroring the EPEAT trajectory [9].

10.2 Stakeholder Incentives

Stakeholder	Incentive	Value received
Parents	Free child protection	Real-time alerts and conversation guidance
Schools	Duty of care fulfilment	Aggregate threat intelligence unavailable elsewhere
Municipalities	Evidence-based resource allocation	Population-level data integrated with SSP
Platforms	DSA/AI Act compliance pathway	Certification providing regulatory presumption of conformity

10.3 Comparison with Existing Approaches

Current approach	Limitation	How the CCF addresses it
Annual surveys (EU Kids Online)	2-3 year delay; sample-based	Real-time, population-level measurement
Helpline data	Only captures children who self-report; research suggests 20-34% of abuse victims never disclose	On-device detection identifies threats in unreported communications
Platform self-reporting	No independent verification	QSA-validated certification with published metrics
Cloud-based monitoring apps	GDPR Art. 5(1)(c) data minimisation concerns	On-device processing; no content transmitted

11. Regulatory Cross-Mapping

Regulation	Mapped Articles	CCF Domains
EU Digital Services Act	Art. 28, 34, 35, 37	CS-AC, CS-CD, CS-GO
EU AI Act	Children as vulnerable group; education AI high-risk	CS-MR, CS-DM, CS-GO
UK Age Appropriate Design Code	All 15 standards	All 6 domains
Denmark Under-15 Law	Social media age restrictions	CS-AC
US COPPA 2.0 / KOSA	All proposed requirements	CS-AC, CS-DM, CS-PR
IEEE P3462	Development, deployment, maintenance	CS-CD, CS-MR, CS-GO
EU CSA Regulation	CSAM detection and reporting	CS-MR
eIDAS 2.0	Age verification	CS-AC

12. Implementation Roadmap

Phase	Timeline	Milestone
Draft & Validate	Months 0-12	CCF v1.0, CAS API specification, 5,000 family users via compliant applications, 6 school pilots
Formalise	Months 12-24	IEEE/CEN submission, first QSA programme, government endorsement
Adopt	Months 24-36	10+ countries, registry operational, platform certifications
Mandate	Months 36-48	EU-wide guidance references Custorian, mandatory for DSA compliance

13. Liability and Scope of Protection

- 1. No guarantee of detection.** The CCF and CCF-compliant systems do not and cannot detect all threats. Detection accuracy will be published following independent validation (Q4 2026). Institutions should not treat CCF-compliant systems as substitutes for human supervision.

2. **No liability transfer.** Deployment does not transfer duty of care obligations to Custorian. Institutions retain their legal obligations under Danish law, the DSA, and applicable legislation.
 3. **Certification scope.** “Custorian Certified” indicates conformity with CCF controls at time of assessment, not the impossibility of incidents. Analogous to PCI DSS compliance.
 4. **Not a law enforcement tool.** Does not identify perpetrators or collect evidence to criminal standards. Mandatory reporting pathways (NCMEC CyberTipline) are triggered for CSAM; investigation is conducted by law enforcement.
-

14. Conclusion

The expiration of the EU ePrivacy derogation has created an unprecedented gap in child protection. The regulatory landscape is accelerating but provides no shared technical standard. Child digital safety is where payment security was before PCI DSS: growing pressure, no common framework.

The Custorian Standard comprises three components: the **CCF** defining 116 auditable controls; the **CAS** providing an open API specification; and the **Certification Programme** enabling independent validation. The on-device detection requirement addresses the tension between child protection and privacy — a tension that contributed to the abandonment of NeuralHash and continues to stall the CSA Regulation. Whether on-device processing resolves the ePrivacy legal question is for data protection authorities to determine, not for the standard to assert.

This paper has been transparent about what remains unvalidated. Independent accuracy testing has not been conducted. The ePrivacy architectural observation requires formal legal assessment. The parental abuse safeguards reduce but do not eliminate misuse risk.

Next milestones: - **Q3 2026:** Odense pilot — 6 schools, ~1,800 families, waitlist-controlled design - **Q4 2026:** Independent accuracy validation by Danish university partner - **Q4 2026:** Publication of accuracy metrics per language and threat category - **2027:** IEEE/CEN submission; first QSA programme; government endorsement

The standard is open source (CC BY-SA 4.0). Custorian invites collaboration from policymakers, researchers, child rights organisations, platform trust and safety teams, and privacy advocates.

For advisory council participation, pilot partnership, or technical review: tanya@custorian.org.

References

Note: References grouped thematically. For IEEE submission, will be renumbered in order of first citation per IEEE style.

- [1] NCMEC, “2023 Reports of Apparent Child Sexual Abuse Material (CSAM),” 2024. Available: <https://www.missingkids.org/content/ncmec/en/press-release/2024/ncmec-releases-2023-csam-statistics.html>
- [2] WeProtect Global Alliance, “Global Threat Assessment 2023,” 2023; citing Crisp (now Resolver), research on grooming escalation timelines in gaming environments.
- [3] UNICEF, “More Than a Third of Young People in 30 Countries Report Being a Victim of Online Bullying,” 2019. Available: <https://www.unicef.org/press-releases/unicef-poll-more-third-young-people-30-countries-report-being-victim-online-bullying>
- [4] CDC MMWR, “Emergency Department Visits for Suspected Suicide Attempts Among Persons Aged 12-25,” 2021; Institute for Family Studies analysis of CDC WISQARS data on self-harm ED admissions, 2009-2022.
- [5] SafetyDetectives, “Comparative Review of Parental Control Software,” 2024.
- [6] EU Kids Online, “EU Kids Online 2024 Survey Findings,” LSE, 2024.
- [7] European Commission, “Digital Services Act — Protection of Minors,” OJ EU, 2022.
- [8] PCI Security Standards Council, “PCI DSS v4.0,” 2022. Available: <https://www.pcisecuritystandards.org>
- [9] Global Electronics Council, “EPEAT Programme Overview,” 2024. Available: <https://www.epeat.net>
- [10] IEEE SA, “P3462 — Draft Recommended Practice for Using Safety by Design in Generative Models to Prioritize Child Safety,” Draft 5, Dec 2025.
- [11] UN Committee on the Rights of the Child, “General Comment No. 25 on Children’s Rights in Relation to the Digital Environment,” 2021.
- [12] Thorn / All Tech is Human, “Safety by Design for Generative AI: Preventing Child Sexual Abuse,” 2024.
- [13] UNICEF, “Policy Guidance on AI for Children,” 2021.
- [14] Euronews, “EU Countries Sign Danish Plan to Boost Child Protection Online (Jutland Declaration),” Oct 2025.
- [15] H. Nissenbaum, “Privacy in Context,” Stanford University Press, 2010.
- [16] D. Solove, “A Taxonomy of Privacy,” U. Penn. Law Review, vol. 154, no. 3, 2006.
- [17] T. Beauchamp and J. Childress, “Principles of Biomedical Ethics,” 8th ed., Oxford, 2019.
- [32] Euronews, “EU Countries Reach Long-Awaited Deal on Online Child Abuse Detection,” Nov 2025.

[33] EDPS, “Extension of Interim Rules to Combat Child Sexual Abuse Online Must Address Shortcomings,” 2026.

[36] FBI, “FBI Warns of Increase in Sextortion Schemes Targeting Minors,” IC3, 2023.

[39] Apple Inc., “Expanded Protections for Children,” Aug 2021 (abandoned Dec 2022).

[40] J. Mayer, “Content Moderation on End-to-End Encrypted Systems,” Princeton CITP, 2021.

Acknowledgments: The author is a contributing member of the IEEE P3462 Working Group. This work is conducted under the auspices of Foreningen Custorian (CVR 46399455), a Danish non-profit association.

Open Source and Intellectual Property: The CCF is licensed CC BY-SA 4.0; the CAS under MIT licence. Anyone may implement CCF controls or build CAS-compatible systems without permission or payment. The “Custorian Certified” designation will be reserved for platforms passing QSA audit or validated SAQ — analogous to PCI DSS compliance marks. Trademark registration is in progress.

Conflicts of Interest: None declared. Custorian is a non-profit with no shareholders.

About the Author: Tanya Becheva is the founder of Foreningen Custorian and a contributing member of IEEE standards on child safety and AI ethics. Her background spans technical programme management at scale within the global technology sector, with a focus on platform safety, cross-functional delivery, and regulatory compliance. She is a parent of two children, which informed the development of Custorian as a standard built from lived experience, not theory. Custorian is domiciled in Odense, Denmark. The Jutland Declaration on child digital safety was signed by 25 EU member states in Horsens, Denmark in October 2025.

Appendix A: Planned Validation Pilot Design

Pilot 1: Odense Schools (planned Q3-Q4 2026)

Design: Waitlist-controlled trial with 6 schools in Odense Kommune. 3 intervention schools deploy a CCF-compliant detection system at study start; 3 matched control schools receive it after 6 months. Schools matched on size, socioeconomic profile, and existing digital safety programmes.

Participants: ~1,800 families (~300 per school), children aged 8-16

Duration: 6 months (intervention vs. waitlist comparison), followed by 6-month open deployment

Ethics: To be submitted to Danish university IRB (partner TBD). Parental consent for all. Child assent for ages 12+. No school permanently denied the intervention.

Primary outcomes: 1. Detection accuracy in real-world conditions (vs synthetic test corpus) 2. False positive rate as experienced by parents 3. Intervention timeliness 4. Parent behavioural response 5. Between-group comparison: SDQ and teacher-reported incident differences at 6 months

Secondary outcomes: 1. Student wellbeing change (SDQ pre/post) 2. Teacher-reported digital safety incidents (pre/post, both groups) 3. Adoption rate and retention 4. Hawthorne effect estimation

Statistical plan: Independent samples t-tests for between-group comparisons. Paired t-tests for within-group. Cohen's d effect sizes. MDE: $d=0.2$, $N=900/\text{group}$, $\alpha=0.05$, $\text{power}=0.80$. Intention-to-treat. Bonferroni correction.

Validation partner: SDU or Aarhus University (TBD). Results submitted to peer-reviewed journal.